

Security incident report

Section 1: Identify the network protocol involved in the incident

DNS over UDP (port 53): The browser performed DNS queries for both yummyrecipesforme.com and greatrecipesforme.com using UDP to resolve each domain to its IP address (e.g or example., 203.0.113.22 and 192.0.2.17).

TCP (port 80) for HTTP: After DNS resolution, the browser established a TCP three-way handshake and sent plain-text HTTP requests (GET / HTTP/1.1) to retrieve the webpage and download the malicious executable.

Section 2: Document the incident

Based on the TCP traffic log, a prompt appeared for a user to download a browser update via an executable file. After accepting the file the browser was redirected to greatrecipesforme.com, where malicious activity was observed.

1. DNS Request (UDP/53): (Translates Domain names ->IP addresses on Port 53)

Device requests DNS for the IP of yummyrecipesforme.com. It came back with 203.0.113.22.

2. HTTP Connection (TCP/80): (HTTP handled on port 80)

Browser does the usual TCP handshake and sends an HTTP GET request. The site responded and included an unsafe JavaScript that triggered the download prompt.

3. Executable update: (TROJAN - hidden in plain site. Misleading Update)

Ran the file (thinking it was a browser update). That script immediately launched a hidden redirect to greatrecipesforme.com.

4. New DNS Request (UDP/53):

Device resolved greatrecipesforme.com to 192.0.2.17.

5. New HTTP Connection (TCP/80):

TCP handshake, GET request, and now the device is pulling malware from the second site.

Section 3: Recommend one remediation for brute force attacks

This was a Brute Force attack because the attacker gained access to the admin password due to it still being set to the default password. There were absolutely no controls that would kick the user from the network so they repeatedly guessed passwords either manually or with a script until one worked.

To stop brute force attacks, specifically with our admin and company passwords, we should change default credentials immediately after redeploying our website. Adding an account lockout, rate limiting, captcha, and MFA is advised and could stop all bots and hackers. I'd also suggest monitoring login attempts and setting up alerts for repeated failures.